

Intrusion Detection (& Intrusion Prevention)



Bild: cloudflare.com

SOC.F2601
Peter Infanger, HSLU I

Intrusion Detection

- Einführung Intrusion Detection Systems (IDS)
 - IDS Technologien
 - NIDS vs. HIDS
 - NIDS & HIDS Produkte
 - IDS Architektur
 - Einführung Intrusion Prevention Systems (IPS)
 - NIPS vs. HIPS
- Abgrenzung EDR/xDR
 - Anhang
 - Technische Aspekte
 - Betriebliche Aspekte
 - IDS/IPS erfolgreich einsetzen
 - Erfolgskriterien
 - Schlussfolgerungen



Was ist "Intrusion Detection"

- "Intrusion Detection" ist die Überwachung von Systemen oder Netzwerken zur Erkennung von sicherheitsrelevanten Ereignissen
- Ein "Intrusion Detection System" (IDS) ist eine Hardware- und/oder ein Software-System zur Automatisierung dieser Überwachung





Prozessmodell von IDS

- Informationsbeschaffung
 - Als Input braucht das IDS-Informationen zu den laufenden Aktivitäten.
 - Netzwerkbasierend durch mithören der Pakete auf dem Netzwerk
 - Hostbasierend durch Überwachung des Computer-Systems
 - Applikationsbasierend durch Überwachung einer bestimmten Applikation
- Analyse
 - Meistens werden sehr viele Informationen gesammelt. Diese müssen analysiert werden.
 - Hauptmethoden sind "Signature Detection" und "Anomaly Detection".
- Reaktion
 - Nach Erkennung eines Ereignisses wird eine Reaktion ausgelöst, z.B. Alarm Meldung, TCP-Reset, usw.

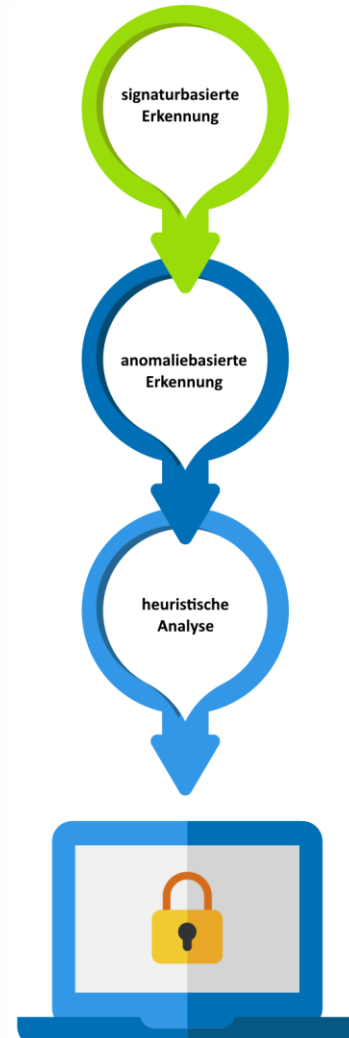
IDS-Technologien

Es gibt mehrere Haupttechniken zur Erkennung von Bedrohungen:

- signaturbasierte Erkennung*
- anomaliebasierte Erkennung
- heuristische Analyse

Viele Anbieter von IDS-Systemen haben die Vorteile dieser Techniken erkannt und einige integrieren alle in ihre Produkte.

Wenn man ihre Stärken und Schwächen kennt, kann man verstehen, wie sie sich gegenseitig ergänzen können.



*interessanter Artikel unter: <https://norbert-pohlmann.com/glossar-cyber-sicherheit/analysekonzpte-von-angriffen>

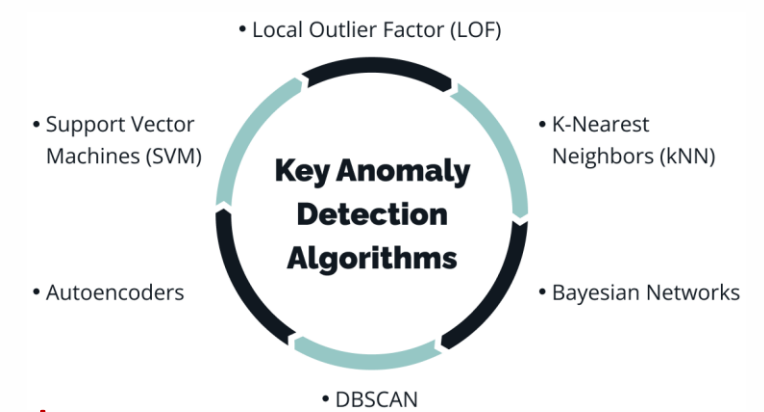


Signaturbasierte IDS-Tools

- Bei einem signaturbasierten IDS, auch **wissensbasiertes** IDS genannt, wird nach **Regeln** oder **Mustern** für bekannten böartigen Datenverkehr gesucht.
- Sobald eine Übereinstimmung mit einer Signatur gefunden wird, wird eine Warnung an den Administrator gesendet.
- Diese Warnmeldungen können Probleme wie bekannte Malware, Netzwerk-Scan-Aktivitäten und Angriffe auf Server rapportieren.

Beispiel: bekannteste Signaturen für AV-Scanner sind die EICAR Virus Test-Files, zu finden unter: <https://www.eicar.org/download-anti-malware-testfile/>

Anomalie-basierte IDS-Tools



- Bei einem anomalie-basierten IDS, auch **verhaltensbasiertes** IDS genannt, ist die Aktivität, welche den Datenverkehr bzw. der ausgeführte Prozess erzeugt hat, viel wichtiger als die übermittelte Nutzlast.
- Ein auf Anomalien basierendes IDS-Tool stützt sich eher auf Baseline als auf Signaturen. Es sucht nach ungewöhnlichen Aktivitäten, die von den **statistischen Durchschnittswerten früherer Aktivitäten** oder **zuvor beobachteter Aktivitäten abweichen**.
- Wenn sich beispielsweise ein Benutzer immer von der Schweiz aus in die IT-Systeme einloggt und auf technische Daten zugreift, ist es ein Warnsignal, wenn sich derselbe Benutzer von Peking aus einloggt und z.B. HR-Daten ansieht.

Heuristische* Analyse

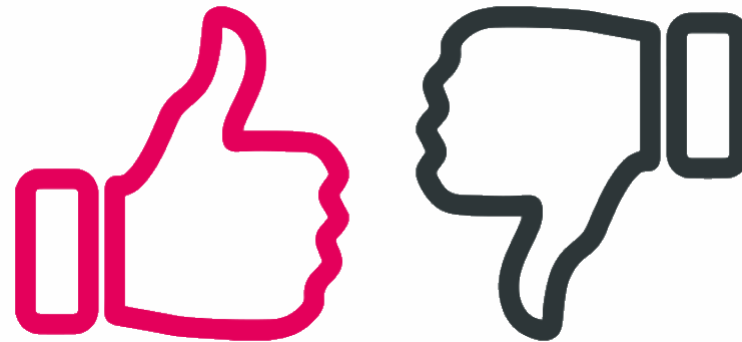


- Heuristik, z.B. in der Malware-Erkennung neuer, unbekannter Viren, schaut auf verdächtige Eigenschaften oder Anomalien in Programmen, welche ähnlich zu denen von bekannter Malware sind.
- Diese Methode beruht auf Algorithmen, die **Vermutungen** über neue Bedrohungen anstellen können, basierend auf **Ähnlichkeiten** zu bereits früher identifizierten Schadprogrammen.

*Der Begriff Heuristik stammt vom griechischen „heurisko“ ab, was „ich finde“ bedeutet.

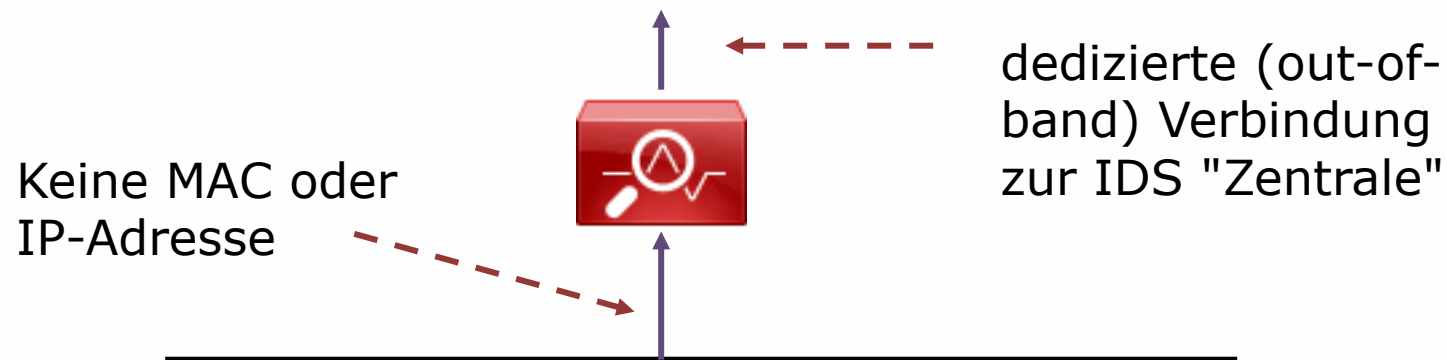
Vor- und Nachteile der Erkennungstechnologien

- Bei der **signaturbasierten** Erkennung treten weniger Fehlalarme auf, aber es werden nur bekannte Signaturen markiert, so dass eine **Sicherheitslücke** für neue und noch nicht identifizierte Bedrohungen entsteht.
- Bei der **anomaliebasierten** Erkennung treten mehr Fehlalarme auf, aber wenn sie richtig konfiguriert ist, werden auch bisher unbekannte Angriffe erkannt.



Netzwerkbasierende IDS → NIDS

- Ein oder mehrere Sensoren die den Datenverkehr auf dem Netzwerk mithören
- Dedizierte Sensoren. Die Sensoren dienen lediglich als Teil des IDS, keine zusätzliche Funktionalität.
- Die Sensoren können "versteckt" werden, indem sie z.B. über keine MAC oder IP-Adresse auf Seite des zu überwachenden Netzes verfügen



Netzwerkbasierendes IDS (1)



- Vorteile:
 - Ein paar gutplatzierte Sensoren können ein grösseres Netzwerk überwachen
 - Wenig Einfluss auf dem bestehenden Netz. Die Sensoren sind passiv
 - Die Sensoren sind sicher und gut versteckt

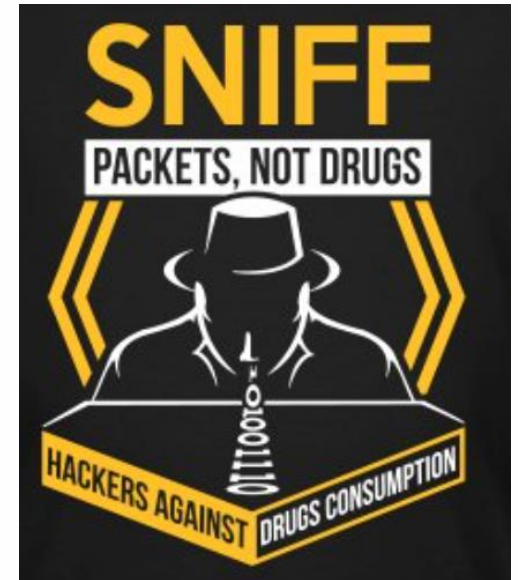
Netzwerkbasierendes IDS (2)



- Nachteile:
 - **Hohe Netzlast.** Ein Sensor verfügt u.U. über ungenügend Leistung, um alle Pakete zu überwachen und zu analysieren. Wichtige Ereignisse gehen evtl. verloren.
 - **Switches:** Ein Sensor wird viele Informationen nicht sehen können. Mögliche Lösungen: "Span-Port", Tap, Hub
 - **Verschlüsselte Daten:** Ein Sensor kann verschlüsselte Daten nicht analysieren.
 - **Erkennen erfolgreicher Angriffe:** Ein Sensor kann erkennen, dass ein Angriff stattfindet, weiss aber nicht immer, ob er erfolgreich war.
 - **Fragmentierte und ungültige Pakete:** In einigen Fällen hatten Sensoren Probleme mit bestimmten Pakettypen. Sensoren könnten evtl. instabil werden oder sogar abstürzen.
 - **Software Bugs:** können dazu führen, dass die Sensoren doch nicht sicher und gut versteckt sind (z.B. Angriff durch "Witty worm"). <https://www.caida.org/research/security/witty/>

Installation von netzwerk- basierenden Sensoren

- Netzbwerkbasierende IDS-Sensoren können an verschiedenen Orten installiert werden, z.B:
 - innerhalb der DMZ
 - wichtige Backbone Verbindungen
 - wichtige Subnetze
 - ausserhalb der Firewall? (zwischen Internet und Firewall)
- Kriterien:
 - interne / externe Attacken?
 - Aktive Netzprotokolle?
(verschlüsselte Daten? anwendungsspezifische Protokolle?)
 - Preis?



Beispiele NIDS (1)



Snort (<https://www.snort.org/>)

- Snort ist eine Open-Source-NIDS-Anwendung mit einer Fülle von Funktionen. Es funktioniert nicht nur als robustes Tool zur Erkennung von Eindringlingen, sondern umfasst auch Paket-Sniffing- und Protokollierungsfunktionen.
- Ähnlich wie man mit OSSEC Regeln und Policies aus der User Community herunterladen kann, stehen auf der Website vordefinierte Regeln für Snort zur Verfügung. Man kann sich auch für Abonnements anmelden, um sicherzustellen, dass Policies für Bedrohungsinformationen auf dem neuesten Stand sind. Die Regeln von Snort können auch nach eigenen Vorgaben angepasst werden, aber die grundlegenden Policies sind bereits ein guter Ausgangspunkt.
- Zu den Ereignissen, die von diesen Richtlinien erkannt werden, gehören Puffer-Overflows, CGI-Angriffe, OS-Fingerprinting und Stealth-Port-Scans. Der Regelsatz enthält sowohl anomalie- als auch signaturbasierte Richtlinien, wodurch der Anwendungsbereich der Anwendung ziemlich breit und umfassend wird.

Rule Header	alert tcp \$EXTERNAL_NET \$HTTP_PORTS -> \$HOME_NET any
Message	msg: "BROWSER-IE Microsoft Internet Explorer CacheSize exploit attempt";
Flow	flow: to_client,established;
Detection	file_data; content:"recordset"; offset:14; depth:9; content:".CacheSize"; distance:0; within:100; pcrc:"/CacheSize\s*=\s*/"; byte_test:10,>,0xffffffff,0,relative,string;
Metadata	policy max-detect-ips drop, service http;
References	reference:cve,2016-8077;
Classification	classtype: attempted-user;
Signature ID	sid:65535; rev:1;

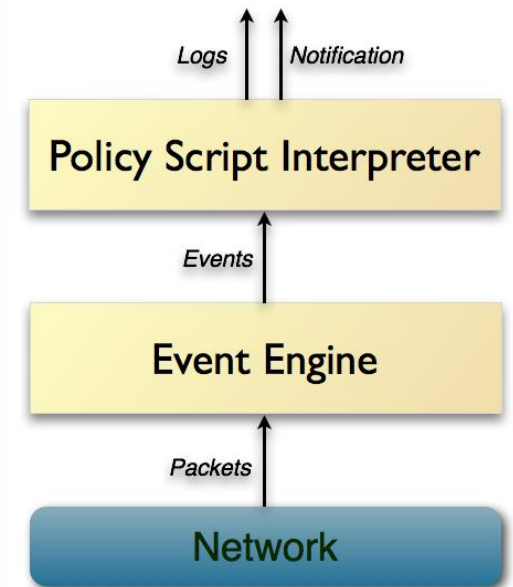
Source: <http://manual-snort-org.s3-website-us-east-1.amazonaws.com/node1.html>

Beispiele NIDS (2)



Zeek (<https://zeek.org/>)

- Zeek ist der neue Name für das Bro-System, wobei bestimmte Komponenten den Namen "Bro" beibehielten. Dieser Netzwerksicherheitsmonitor unterscheidet sich in mehrfacher Hinsicht von herkömmlichen IDSs.
- Dieses Open-Source-NIDS verwendet eine domänenspezifische Skriptsprache, die standortspezifische Überwachungsrichtlinien erleichtert und es als IDS-Tool sehr anpassungsfähig macht. Es tauscht Informationen in Echtzeit über Schnittstellen mit anderen Anwendungen aus, protokolliert Aktivitäten, die in einem High-Level-Archiv gespeichert werden, und verfügt über Analysatoren für zahlreiche Protokolle, so dass man semantische Analysen auf der Anwendungsebene durchführen kann.



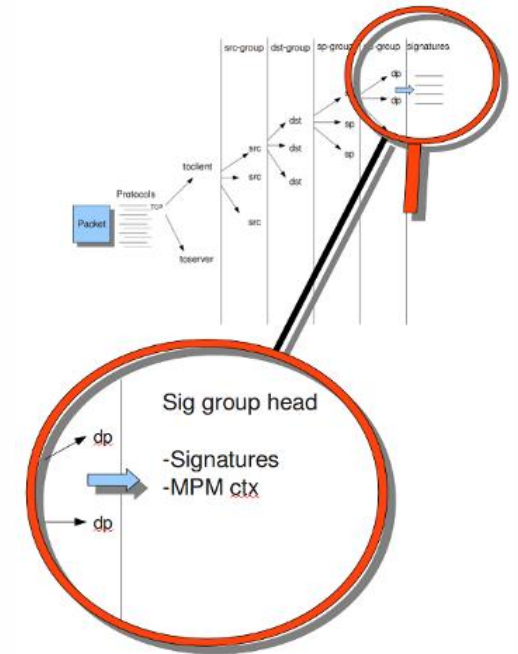
Beispiele NIDS (3)

Suricata

Open Source IDS / IPS / NSM engine

Suricata (<https://suricata.io/>)

- Suricata ist ein sehr anspruchsvolles, sehr schnelles, freies Open-Source-IDS. Es kann ID in Echtzeit, Inline Intrusion Prevention, offline pcap-Verarbeitung und Netzwerksicherheitsüberwachung durchführen.
- Durch die Kombination von IDS und IPS ist es als Sicherheitstool sehr effektiv. Mit seiner umfangreichen Regel- und Signatursprache kann Suricata den Netzwerkverkehr untersuchen.
- Es bietet Lua-Scripting*-Unterstützung, die bei der Erkennung besonders komplexer und fortgeschrittener Bedrohungen hilft. Suricata unterstützt alle gängigen Ausgabe- und Eingabeformate und lässt sich leicht mit anderen Datenbanken (wie Splunk, ELK-Stack, etc.) integrieren.



* <https://suricata.readthedocs.io/en/suricata-6.0.0/rules/rule-lua-scripting.html>
<https://docs.suricata.io/en/latest/configuration/suricata-yaml.html#detection-engine>

Beispiele NIDS (4)

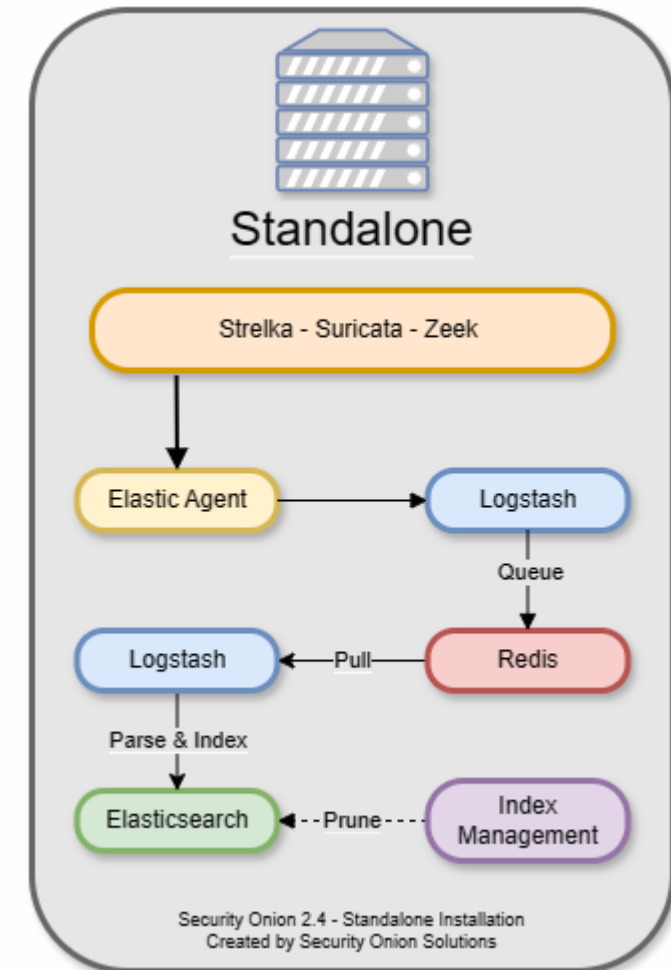


Security Onion (<https://securityonionsolutions.com/>)

- Bei diesem Tool bzw. Toolsammlung handelt es sich um eine quelloffene, freie Linux-Distribution, die für die Verwaltung von Protokollen, die Erkennung von Eindringlingen und die Überwachung der Unternehmenssicherheit entwickelt wurde.
- Security Onion ist im Wesentlichen eine Suite von Sicherheitstools, von denen jedes für sich genommen beliebt ist; dazu gehören Strelka*, Zeek, Suricata, Wazuh, NetworkMiner, ELK-Stack und CyberChef.
- Der Vorteil dieses Ansatzes ist natürlich, dass das Tool dadurch sehr umfassend und vielseitig ist und so ziemlich jeden Aspekt der IT-Sicherheit abdeckt. Das Problem bei einer Suite von Tools ist jedoch die Schwierigkeit ihrer Integration aufgrund der Komplexität.
→ Aus diesem Grund ist eine einheitliche Lösung manchmal vorzuziehen.

*Strelka is a real-time file scanning system used for threat hunting, threat detection, and incident response. It's purpose is to perform file extraction and metadata collection at huge scale.

Source: <https://docs.securityonion.net/en/2.4/architecture.html#architecture>

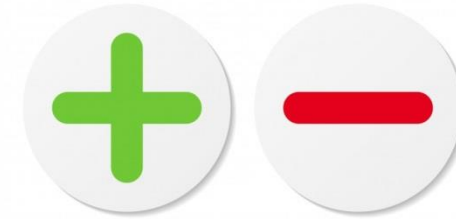


Hostbasierende IDS → HIDS

- Sensor ist auf dem Host-System installiert.
(Mit "host" sind alle Arten von Computersystemen, z.B. Server usw. gemeint)
- Kann Audit-Logs, System-Logs vom Host-System analysieren
- Kann Prozesse und andere lokale Aktivitäten überwachen
- Kommuniziert mit dem zentralen IDS

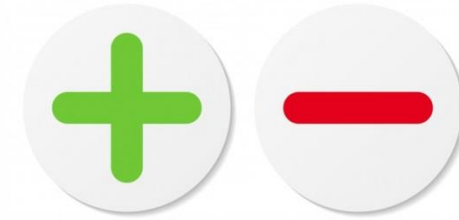


Hostbasierende IDS (1)



- Vorteile:
 - Kann lokale Aktivitäten überwachen, die ein Netzwerk-Sensor nicht sehen kann
 - Kein Problem mit verschlüsselten Daten (solange Daten lokal verschlüsselt/entschlüsselt werden)
 - Kein Problem mit "ge-switchen" Netzwerken ("MAC-Filterung" der Switches)
 - Erfolgreiche Angriffe können erkannt werden.
 - Betriebssystem Logfiles / Audit-Logs können überwacht werden

Hostbasierende IDS (2)



- Nachteile:
 - Verwaltungs- und Konfigurationsaufwand. Ein Host-Sensor pro überwachtes System.
 - Obwohl erfolgreiche Angriffe erkannt werden können, ist der Sensor grundsätzlich gefährdet und könnte vom Angreifer deaktiviert oder umkonfiguriert werden.
 - Netzwerk-Scans werden nicht erkannt. Der Sensor sieht nur die Pakete, die an das Host-System adressiert sind.
 - Zusätzliche, teils beträchtliche, Ressourcenbindung auf dem Host-System.
 - Eventuell negative Auswirkungen auf dem Host-System beim Absturz der IDS-Sensor Software

Installation von hostbasierenden Sensoren

- Auf welchen Systemen sollten hostbasierende IDS-Sensoren installiert werden?
 - Auf allen Host-Systemen? Wahrscheinlich nicht realistisch – Aufwand? Preis?
 - Nur auf kritischen Systemen? Web-Server, Applikations-Server, Domain-Controller, ...
 - Unterschiedliche OS → werden diese unterstützt?
- Preis?



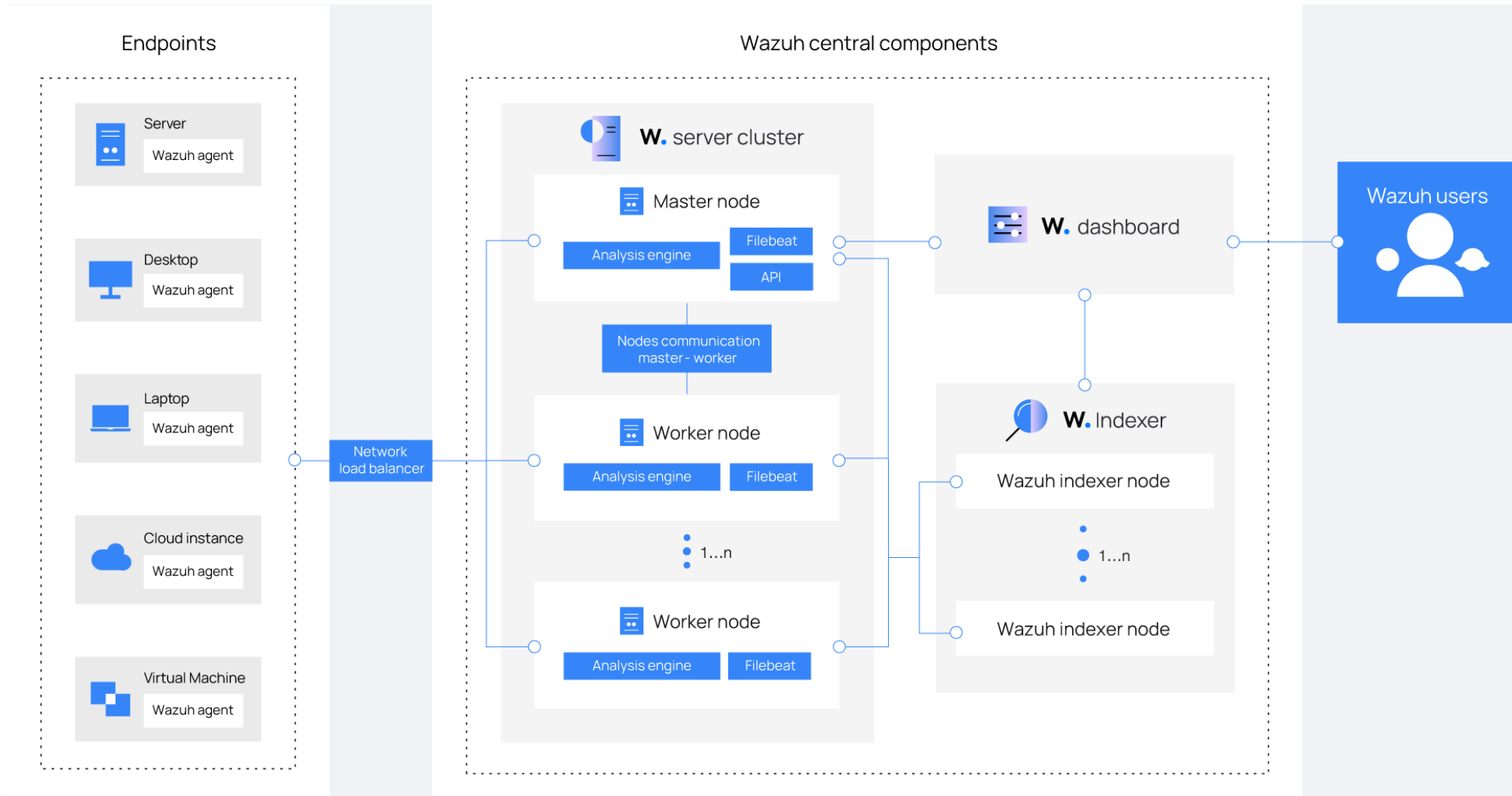
Beispiele HIDS (1)



Wazu (<https://wazuh.com/>)

- Wazuh ist eine Open-Source-Sicherheitsplattform welche die Funktionen zur Erkennung, Überwachung und Reaktion auf Bedrohungen bietet. Es kombiniert die Fähigkeiten eines Security Information and Event Management (SIEM) Systems mit einem Host Intrusion Detection System (HIDS).
- Mit Wazuh können Unternehmen ihre IT-Infrastruktur überwachen, potenzielle Bedrohungen frühzeitig erkennen und darauf reagieren. Es unterstützt verschiedene Umgebungen, einschliesslich On-Premises, virtualisierte, containerisierte und Cloud-basierte Umgebungen.
- Einige der Hauptfunktionen von Wazuh sind:
 - Überwachung und Alarmierung: Überwacht die IT-Infrastruktur und sendet Alarme bei verdächtigen Aktivitäten.
 - Datenaggregation und -analyse: Sammelt und analysiert Sicherheitsdaten, um Bedrohungen und Anomalien zu erkennen.
 - Integration: Kann mit anderen Sicherheitstools und SIEM-Lösungen integriert werden, um eine umfassende Sicherheitslösung zu bieten.

Wazuh Architektur



Quelle: <https://documentation.wazuh.com/current/getting-started/architecture.html>

Beispiele von HIDS (2)



OSSEC (<https://www.ossec.net/>)

- Diese kostenlose Anwendung ist eine der ältesten verfügbaren Open-Source-Optionen. Technisch gesehen handelt es sich zwar um ein HIDS, aber es bietet auch einige Tools zur Systemüberwachung, die man eher in einem NIDS finden würde. Wenn es um Protokolldaten geht ist OSSEC sehr effizient, verfügt jedoch über keine Benutzeroberfläche. Man kann dies umgehen, indem man ein Open-Source-Dashboard wie Kibana oder Graylog verwendet.
- OSSEC organisiert und sortiert Protokolldateien und verwendet anomalie-basierte Erkennungsstrategien und -richtlinien. Da es sich um eine Open-Source-Anwendung handelt, kann man auch vordefinierte Regelsätze zur Bedrohungsaufklärung aus der Gemeinschaft anderer Benutzer herunterladen, welche OSSEC installiert haben.





Beispiele von HIDS (3)

Samhain (<https://la-samhna.de/samhain/>)

- Das kostenlose HID-System Samhain bietet Dateisicherheitsfunktionen wie Integritätsprüfungen, Überwachung und Analyse. Das vielleicht einzigartigste Merkmal ist die Überwachung im Stealth-Modus, welche die Überwachung ermöglicht ohne dass ein Hacker dies bemerkt.
- In vielen Fällen von Cyberattacken können Eindringlinge Erkennungsprozesse identifizieren und stoppen, aber ihre proprietäre kryptografische Funktion verhindert, dass Hacker ihre Aktivität bemerken und Suchvorgänge durchführen.
- Das Tool verwendet einen PGP-Schlüssel, um auch zentrale Protokolldateien und Sicherungen zu schützen.
- Weitere Funktionen sind die Möglichkeit, Rootkit-Erkennung und Port-Überwachung durchzuführen und versteckte Prozesse zu erkennen welche auf den Geräten ausgeführt werden.

→ Letzte Aktivitäten dieses Projektes daten vom Januar 2026, Teile davon sind aber bedeutend älter (2011) → Einsatz sollte gut überlegt sein!

Beispiele von HIDS (4)



AIDE- Advanced Intrusion Detection Environment (<https://aide.github.io/>)

- AIDE ist ein klassisches und zuverlässiges Open-Source-Tools für File Integrity Monitoring (FIM). Es ist leichtgewichtig, stabil und wird häufig in sicherheitskritischen oder compliance-orientierten Umgebungen eingesetzt.
- AIDE ist ein Host-basiertes IDS-Tool, das Dateiintegrität überwacht, indem es Hashes und Metadaten von Dateien vergleicht. Es funktioniert ähnlich wie Tripwire*, ist aber vollständig Open Source.
- Eigenschaften:
 - File Integrity Monitoring (FIM): Überwacht Dateien, Verzeichnisse und Systemkonfigurationen.
 - Hash-basierte Prüfungen: Nutzt starke Algorithmen wie SHA-256 oder SHA-512.
 - Baseline-Vergleich: Erstellt eine Referenzdatenbank und erkennt jede Abweichung.
 - Hohe Konfigurierbarkeit: Flexible Regeln für unterschiedliche Pfade und Prüfmethoden.
 - Sehr ressourcenschonend: Keine Daemons, keine Echtzeitüberwachung, ideal für Cron-Jobs.
 - Plattformunabhängig: Läuft auf nahezu allen Unix/Linux-Systemen.
- Nachteil: nur auf Linux/Unix Systemen verfügbar

*Quelle: <https://www.tripwire.com/>



Applikationsbasierende IDS (1)

Sie überwachen nicht das gesamte System oder Netzwerk, sondern konzentrieren sich gezielt auf das **Verhalten einzelner Anwendungen**, um Manipulationen, Missbrauch oder Anomalien zu erkennen.

Sie erkennen Angriffe, die direkt auf die Anwendung abzielen – z. B. Web-Angriffe, API-Missbrauch oder unerwartete Prozessaktivitäten.

Typische Erkennungsmerkmale:

- Ungewöhnliche Eingaben oder Requests
- Abweichungen vom normalen Programmverhalten
- Manipulierte Konfigurationsdateien
- Unerwartete Systemaufrufe
- Anomalien in Log-Dateien

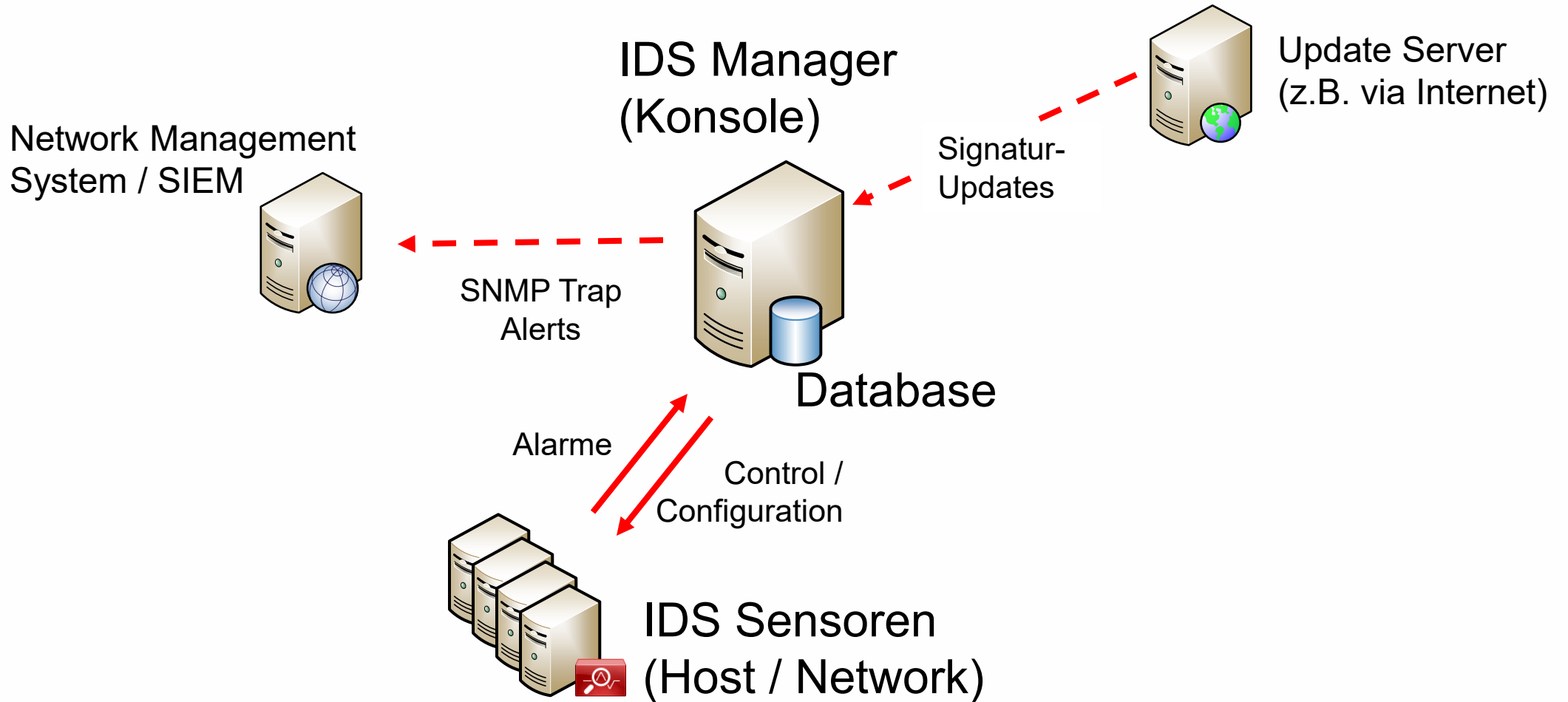


Applikationsbasierende IDS (2)

Beispiele für applikationsbasierte IDS

1. **ModSecurity** (Web Application Firewall / App-IDS), Open Source, überwacht Webanwendungen (Apache, Nginx, IIS) und erkennt SQL-Injection, XSS, Command Injection, Path Traversal. Verwendet OWASP Core Rule Set
2. **AppArmor** (mit teilweiser App-IDS-Funktionalität). Überwacht und kontrolliert das Verhalten einzelner Anwendungen. Erkennt und blockiert unzulässige Aktionen. Ist Profilbasiert (Whitelisting).
3. **SELinux** (ähnlich wie AppArmor) Mandatory Access Control für Anwendungen. Erkennt Policy-Verstösse und wird oft als sicherheitsverstärkende App-IDS-Komponente genutzt.
4. **Fail2ban** (teilweise App-IDS). Analysiert Logfiles einzelner Anwendungen, erkennt Brute-Force-Angriffe und reagiert automatisch (z.B. IP-Blockierung).

Beispiel IDS Architektur



Kommunikation Sensor ↔ Konsole

- Anforderungen an die Kommunikation zwischen Sensoren und Konsole:
 - Zuverlässigkeit
 - Vertraulichkeit
 - Integrität
 - Authentisierung
-
- Proprietäre Protokolle im Einsatz - Interoperabilität zwischen unterschiedlichen Herstellern nicht vorhanden!

IDS Ziele

- Das ideale IDS sollte den Sicherheitsverantwortlichen über Angriffen informieren:
 - mit 100% Zuverlässigkeit
 - keine **False Positives**
 - keine **False Negatives**
 - schnell (innerhalb 1 Minute)
- Inklusive Beschreibung der Attacke sowie entsprechende Empfehlungen
- Das ideale IDS sollte ohne grossen Aufwand installiert und konfiguriert werden können





Klassifizierung von Alarmstufen

- Alarm-Meldungen werden meistens als "Hoch", "Mittel", "Tief" eingestuft (red – orange – yellow)
- Ein Alarm von Stufe "Hoch" könnte evtl. eine SMS-Meldung auslösen
- ACHTUNG: Alarm-Stufen sind sehr subjektiv und umgebungsabhängig.
Vorsicht beim automatischen auslösen von SMS-Meldungen:
Beispiel:
Port Scan innerhalb der DMZ → HOCH
Port Scan vom Internet → TIEF

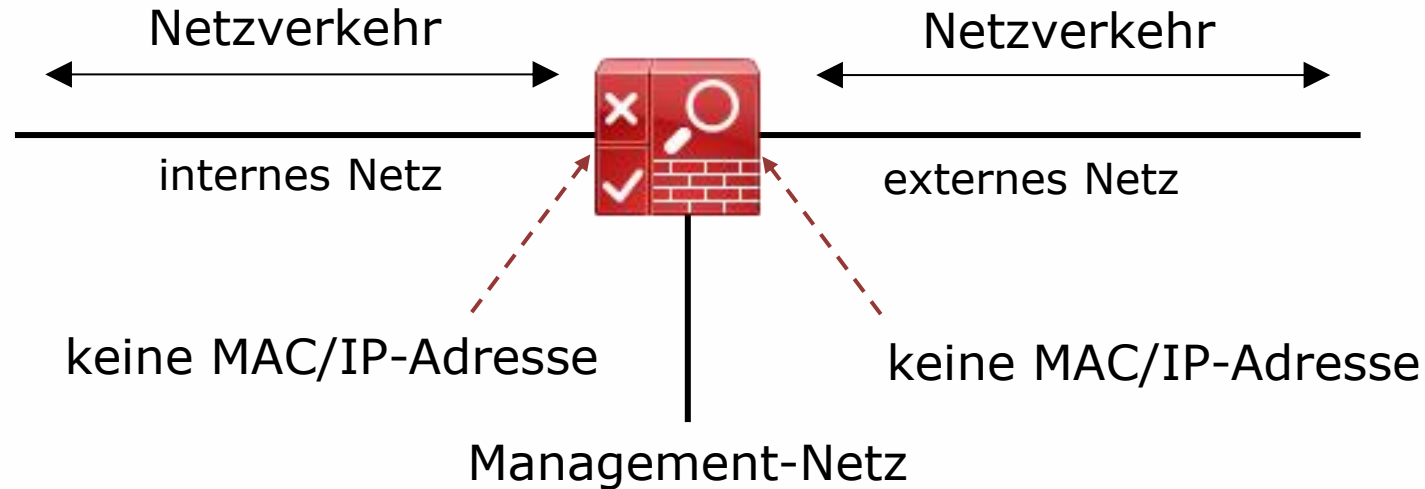
Einführung IPS

- Herkömmliche IDS ist reaktiv, besser wäre Präventiv
→ Intrusion Prevention Systems (IPS)
- Hostbasierender IPS-Sensor: HIPS
- Netzwerkbasierender IPS-Sensor: NIPS



Das grundsätzliche Ziel eines Intrusion Prevention Systems (IPS) ist einfach: Anstatt einen Angriff einfach nur zu erkennen ist es besser, den Angriff zu verhindern bevor ein Schaden entstehen kann. Manch einer mag argumentieren, dass ein traditionelles IDS dies bereits leisten kann, zum Beispiel kann der Sensor eine TCP-Sitzung durch Setzen des RST-Bits beenden. Andererseits könnte man argumentieren, dass dies zu spät ist, der Angriff wurde bereits gestartet und könnte erfolgreich gewesen sein, noch bevor der Sensor die Möglichkeit hatte, die Verbindung zu beenden.

Netzwerkbasierende IPS → NIPS

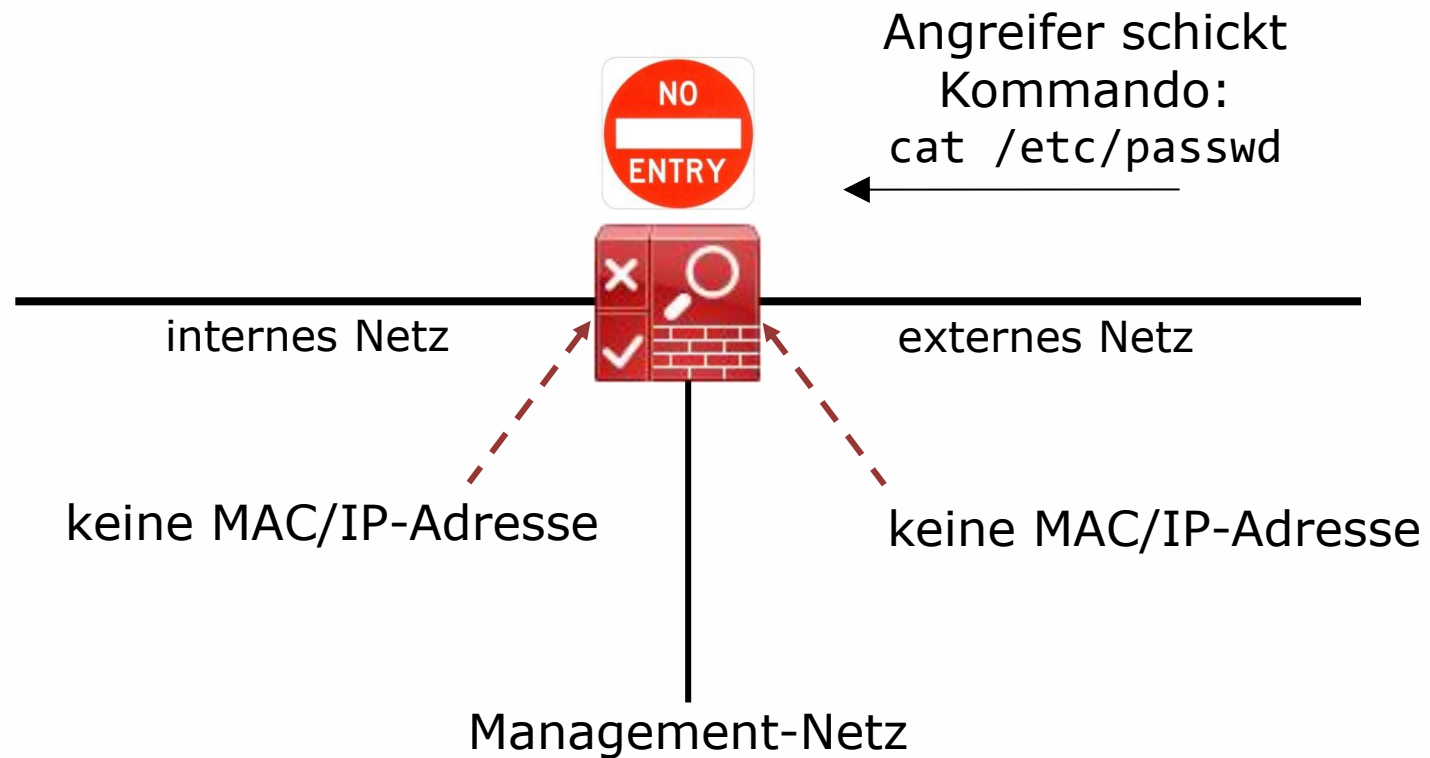


Ein netzwerkbasierter IPS-Sensor wird direkt im Netzwerk installiert, so dass alle Pakete das Gerät durchlaufen. Wenn Pakete an der "externen" Schnittstelle eingehen werden können sie zur Verarbeitung der Detection Engine übergeben werden, ähnlich wie bei einem herkömmlichen IDS-Sensor.

Wird das Paket jedoch als bösartig erkannt, so wird nicht nur ein Alarm ausgelöst, sondern das Paket kann auch gleich verworfen werden, d. h. es wird nicht an die "interne" Netzwerkschnittstelle gesendet, so dass das Endgerät den Angriff nie sieht.

→ Der Angriff wird also nicht nur erkannt, sondern auch verhindert.

Netzwerkbasierende IPS Sensoren



Vorteile & Nachteile

- ✓ Unterbrechen bevor/gleich was passiert
- ✓ Benötigt keinen manuellen Eingriff



- ✗ Mögliche Denial-Of-Service beim Absturz des Sensors
- ✗ Fehlverhalten bei "False-Positives"
- ✗ Netzlast/Netzwerkbandbreite!
- ✗ Latency



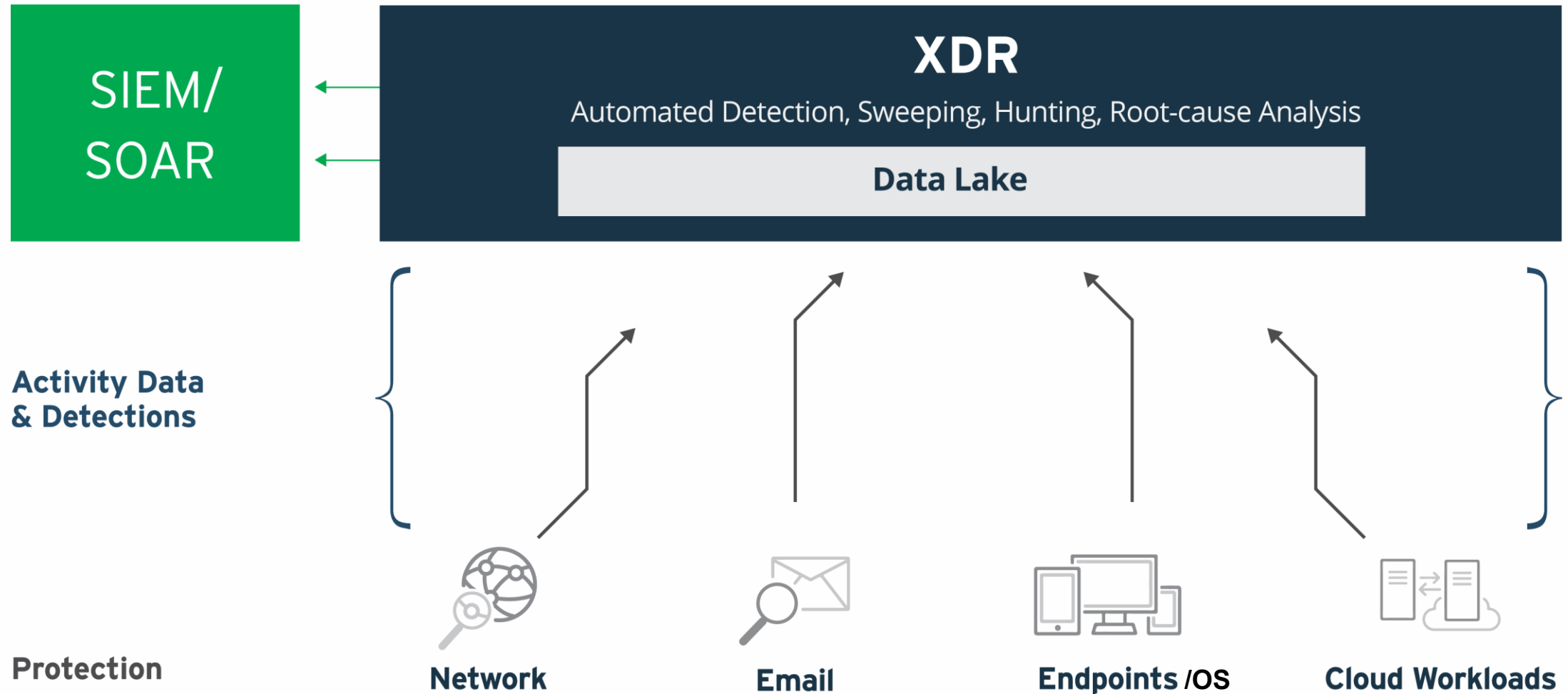
Hostbasierende IPS → HIPS

- Software Agent auf Host-System (ähnlich wie HIDS)
 - Je nach Produkt:
 - Abfangen von System-Calls
 - Analyse des Verhaltens bestehenden Applikationen
 - Integrierte Firewall und / oder lokale Proxy
 - usw.
 - Vorsicht: Unterschiedliche Arten von Security-Produkten werden heute auch als "Host IPS" angeboten (z.B. Desktop Firewall, "Address Space Layout Randomization" Software, usw.)
- siehe auch Applikationsbasierte IDS

Abgrenzung zu EDR – XDR Systemen

- Moderne HIDS werden heutzutage eher als EDR (Endpoint Detect and Response) oder XDR (Extended Detection and Response) Systeme angepriesen.
 - xDR erfassen und korrelieren Daten automatisch auf mehreren Sicherheitsebenen – Endpunkt-OS, E-Mail, Internetverbindungen, Server-Connection, Cloud-Access und Netzwerk.
 - Dies ermöglicht eine schnellere Erkennung von Bedrohungen und verbessert Untersuchungs- und Reaktionszeiten durch Sicherheitsanalysen.
 - Bieten meistens auch Prevention-Funktionalitäten an.
- xDR Systeme lösen zunehmend traditionelle HIDS/NIDS Systeme ab!

Abgrenzung zu EDR – XDR Systemen



Quelle: https://www.trendmicro.com/de_de/what-is/xdr.html

Status heute

- IDS und IPS haben viel gemeinsam, z.B.:
 - Architektur (zentrale Konsole, Datenbank, Kommunikation zwischen Sensor & Konsole, usw.)
 - Betriebliche Aspekte (Signatur Updates, usw.)
- Reine IDS-Produkte kaum noch verfügbar. Fast alle Produkte werden als IPS verkauft ➔ und es geht in Richtung xDR!

Seit der Einführung von IPS im Gegensatz zu IDS haben die Hersteller ihre IDS-Produkte aufgerüstet oder ersetzt, welche nun hauptsächlich als IPS vermarktet werden, obwohl manche auch den Begriff Intrusion Detection and Prevention Systems (IDPS) verwenden.

Traditionelle IDS-Produkte sind mittlerweile selten. Wenn ein Hersteller von einem IPS spricht, handelt es sich in den meisten Fällen um eine oder mehrere Netzwerk-Appliances, d. h. NIPS, im Gegensatz zu einem Host-Intrusion-Detection- oder -Prevention-System.

Status heute (2)

- Oft sind nur ein Bruchteil der verfügbaren Signaturen im Blocking-Modus aktiviert → IPS funktioniert zum grössten Teil als IDS

Selbst wenn eine NIPS-Appliance inline installiert ist, werden in der Realität praktisch alle Signaturen nur im Erkennungsmodus konfiguriert sein (um die störenden Auswirkungen von *false-positives* zu minimieren), im Gegensatz zum Blocking-Modus, d. h. der NIPS-Sensor arbeitet als NIDS.

Die betrieblichen Aspekte sind unverändert, d. h. es müssen aktualisierte Signaturen installiert werden, auf Alarme reagiert werden usw.

- IPS wird manchmal zum Schutz von Systemen verwendet, welche nicht oder nur selten gepatcht werden können → **virtuelles Patching**

Anhang

- Technische Aspekte
- Zusatz-Funktionalitäten
- Betriebliche Aspekte
- Erfolgskriterien & Schlussfolgerungen

Technische Aspekte NIDS (kleine Intro)

- Port Scans und IDS/IPS
- Web-Hacking und IDS/IPS
- Zusätzlich Funktionalität

Angesichts der Beliebtheit von Port-Scans bei Hackern und Skript-Kiddies sollten wir erwarten, dass dies eine der ersten Angriffssignaturen wäre, die in jedes IDS/IPS-Produkt aufgenommen wird.

Dieser Abschnitt befasst sich mit den Problemen bei der Erkennung von Port-Scans - es stellt sich heraus, dass dies alles andere als trivial ist und dass ein geschickter Hacker in der Lage sein kann Systeme zu scannen, ohne von einem IDS/IPS erkannt zu werden.

Erkennung von Port Scans

- Wenn ein IDS/IPS einen Port-Scan erkennen möchte, dann ist die einfachste Methode, nach einer bestimmten Anzahl von Verbindungsversuchen zu separaten Ports auf einer einzelnen IP-Adresse innerhalb einer bestimmten Zeitspanne zu suchen.
- Einige Versionen verwendeten z. B. Port-Scan-Schwellwerte von 30 Ports innerhalb von 30 Sekunden, während andere Produkte viel niedrigere Schwellenwerte von 4 Ports und 3 Sekunden verwendeten:
einfachste Port Scan Erkennung:
 - N Ports in M Sekunden an 1 IP-Adresse
z.B. N = 30, M = 30 Sek, N = 4, M = 3 Sek
- Diverse andere Algorithmen möglich

Erkennung von Port Scans (2)

Aber: diverse Evasion* Methoden auch möglich, z.B.

- Langsame Port-Scans
- Begrenzte Anzahl Ports
- Distributed Port Scan (mehrere Source Systeme)
- ...
- Das bedeutet zum Beispiel, dass wenn ein Angreifer seine Scans auf weniger als 30 Ports beschränkt, z. B. indem er nur nach bekannten Diensten wie telnet, ftp, finger, http usw. scannt, seine Port-Scans NICHT unbedingt erkannt werden.
- Oder wenn der Port-Scan relativ langsam ausgeführt wird, z. B. indem alle 2 Sekunden 1 Port gescannt wird, dann wird der Port-Scan ebenfalls unentdeckt bleiben. Der Port-Scanner ***nmap*** enthält eine Option, mit der die Scan-Rate der Ports gesteuert werden kann. Es wurden auch zahlreiche weitere Umgehungstechniken vorgeschlagen, wie z.B. die Durchführung von verteilten Port-Scans, die von mehreren Quellsystemen ausgehen, usw.

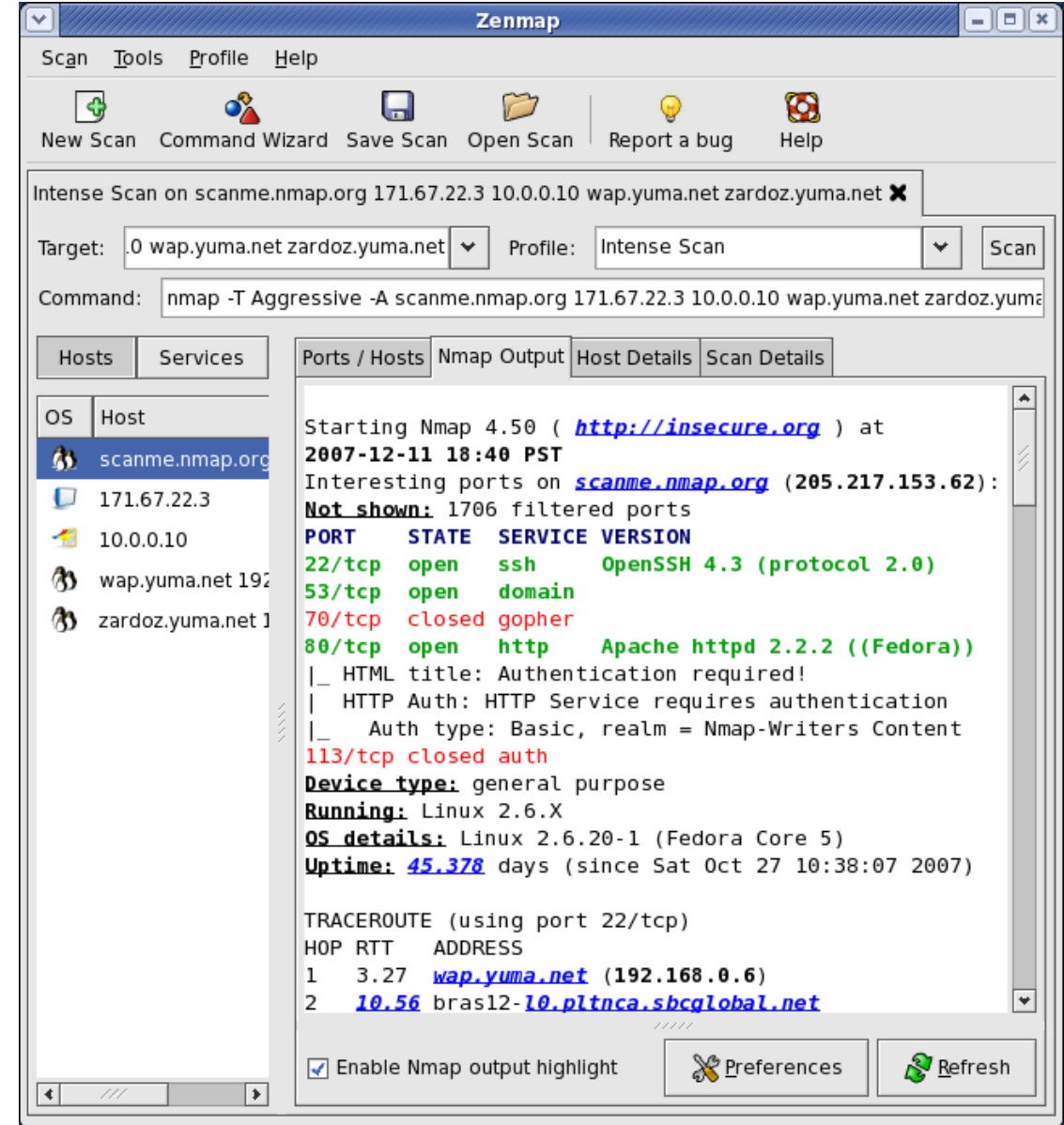
*Evasion: Umgehung, Ausweichen

Erkennung von Port Scans (3)

Es wird deutlich, dass die Erkennung eines Port-Scans nicht trivial ist und es keine einfache Möglichkeit gibt, Port-Scans mit 100-prozentiger Zuverlässigkeit zu erkennen.

Zu diesem Thema wurde viel Forschung betrieben, mit verschiedenen Vorschlägen wie statistischen Profilen, Wahrscheinlichkeitsberechnungen usw.

Es ist zu beachten, dass einige dieser Vorschläge komplexe mathematische Formeln beinhalten.



Web-Hacking und IDS/IPS

- Bei HTTP gibt es mehrere Methoden ein URL zu schreiben. Z.B:
 - phf = ph%66 = %70%68%66 = (usw.)
 - Gross / Klein Schreiben? (index.htm = INDEX.HTM ?)
- Je nach Web-Server: "/" = "\"
- "Path Obfuscation", z.B:
www.victim.ch/images/old/../../cgi-bin/phf oder
www.victim.ch/cgi-bin/./phf
- Unicode
- Mögliche Lösung: "HTTP Normalisation"

Web-Hacking und IDS/IPS

- Einsatz von SSL
- Anwendungsspezifische Cookies und/oder URLs
- Z.B. Zugriff auf vertrauliche Daten von anderen Kunden durch Manipulation der URL:
 - `www.victim.com/get_equities?kunden_nr=12345`
- Z.B. Zugriff auf vertrauliche Daten durch Manipulation eines Cookies:
 - Cookie: `SessionID=12345`
- Diese Manipulationen werden höchstwahrscheinlich NICHT erkannt
- Web-Logfiles nützen u.U. wenig – manipulierte Cookies werden selten in den Log-Dateien gespeichert
- Mögliche Lösung: Überprüfung von Cookies, URL, usw. innerhalb der Web-Anwendung. Beim Erkennen eines Fehlers, Alarm auslösen

Zusätzliche Funktionalität (Auswahl)

- Analyse von SSL
- DLP (eingeschränkt)
- Virtual Patching
- Event Correlation
- Integration SIEM
- Reporting



Zusätzliche Funktionalität (1)

Analyse von SSL

- Einige IPS-Produkte sind in der Lage, den Inhalt von SSL-Verbindungen zu analysieren. Dies impliziert, dass das Gerät als SSL-Endpunkt konfiguriert ist und nicht einfach eine transparente Appliance ist.

DLP – Data Loss Prevention

- Einige IPS-Produkte enthalten (begrenzte) Funktionen zum Schutz vor Datenlecks.

Virtual Patching

- Obwohl es vielleicht nicht explizit als solches beschrieben wird, unterstützen praktisch alle IPS-Produkte eine Form von "virtuellem Patching", d. h. eine oder mehrere speziell definierte Regeln, um die Ausnutzung einer bestimmten Sicherheitslücke zu verhindern. Die Absicht ist, ein Endsystem zu schützen, das (noch) nicht gepatcht wurde (oder nicht gepatcht werden kann).

Zusätzliche Funktionalität (2)

Event Correlation

- Viele IPS-Produkte versuchen mehrere Ereignisse, möglicherweise von mehreren Sensoren, zu korrelieren, um die Erkennung zu verbessern und dem Endbenutzer zu helfen, sich auf die wichtigsten Sicherheitsereignisse zu konzentrieren.

Integration SIEM

- Einige IPS-Produkte beinhalten die Integration mit externen Systemen zur Überwachung von Sicherheitsvorfällen und Ereignissen (die in der Regel von derselben Firma entwickelt und verkauft werden).

Reporting

- Abgesehen von sehr einfachen IPS-Installationen (z. B. eine rudimentäre Installation von Snort), beinhalten alle IPS-Produkte eine Form von Reporting. Je nach Produkt kann dies in hohem Masse anpassbar sein.

IPS Betriebliche Aspekte

Beim Einsatz eines IDS/IPS gibt es neben den technischen Aspekten wie der korrekten Konfiguration der Angriffssignaturen usw. auch viele betriebliche Aspekte zu beachten.

Im Besonderen:

- Alarm Handling / Reporting
- Incident Response Procedures
- Signature Updates
- Automatisch oder Manuell
- System Überwachung
- System Wartung
- Software Updates / Patches
- Backup
- IPS-Outsourcing?

IPS Betriebliche Aspekte (1)

Alarm Handling / Reporting

- Für die Analyse und das Reporting der Alarme, die unweigerlich vom IDS/IPS generiert werden, sollten ausreichend Zeit und Ressourcen eingeplant werden. Es macht wenig Sinn, die neueste IDS/IPS-Technologie zu installieren, nur damit sie Einbruchsversuche in einer Logdatei protokolliert, die nie untersucht wird. Ebenso wenig bringt ein IDS/IPS, das zahlreiche Alarme generiert, etwas, wenn niemand zur Verfügung steht (oder geschult ist), um entsprechend zu reagieren.

Incident Response Procedures

- Für den Fall, dass es tatsächlich zu einem Sicherheitsvorfall kommt, sollten entsprechende Incident-Response-Verfahren entwickelt werden.

IPS Betriebliche Aspekte (2)

Signatur Updates

- Ähnlich wie bei Antivirenprodukten, deren Virendefinitionsdateien ständig aktualisiert werden müssen, müssen auch die Angriffssignaturen für IDS/IPS-Produkte ständig aktualisiert werden, wenn neue Sicherheitslücken und auch neue Angriffsmethoden entdeckt werden. Obwohl die meisten IDS/IPS-Produkte mittlerweile eine Form von automatisierten Signatur-Updates enthalten, sollten diese Updates immer noch manuell überprüft werden, um sicherzustellen, dass die neuen Signaturen für Ihre lokale Umgebung angemessen konfiguriert sind (z. B. Deaktivieren von Signaturen, die wahrscheinlich Fehllarme erzeugen, Ändern der Standard-Angriffspriorität, wo dies angebracht ist, usw.) Beachten Sie, dass dies ein wichtiger Unterschied zu den automatisierten Signatur-Updates für Antiviren-Produkte ist - bei Antiviren-Produkten sind alle Signaturen unabhängig davon aktiviert; dies ist bei IDS/IPS sicherlich nicht der Fall.

IPS Betriebliche Aspekte (3)

System Überwachung

- Abgesehen von dem Aufwand, der für die Überwachung und Reaktion auf Alarme im Zusammenhang mit erkannten oder wahrgenommenen Sicherheitsvorfällen erforderlich ist, können Zeit und Ressourcen für die grundlegende Systemüberwachung benötigt werden, z. B. um sicherzustellen, dass alle Sensoren weiterhin mit der zentralen Managementkonsole kommunizieren. Dies war vor allem in der Vergangenheit ein Problem bei verschiedenen kommerziellen Produkten, bei denen die Zuverlässigkeit der Kommunikation zwischen Konsole und Sensoren deutlich geringer war, als sie hätte sein müssen.

IPS Betriebliche Aspekte (4)

System Wartung & Backup

- Leider sind Intrusion Detection / Prevention Systeme nicht wartungsfrei, Zeit und Ressourcen werden auch für die Installation von Software-Updates (d.h. zusätzlich zu den Signatur-Updates) und die Installation von Patches / Bugfixes benötigt. Vergessen Sie nicht, dass auch ein IDS/IPS anfällig für Angriffe ist; daher kann es notwendig sein, die neuesten Patches unverzüglich zu installieren.

IPS Betriebliche Aspekte (5)

IPS Outsourcing

- Einige Unternehmen bieten inzwischen IDS/IPS-Outsourcing an. Der Hauptvorteil ist, dass diese Unternehmen die Ressourcen haben (oder haben sollten), um 24 Stunden am Tag, 7 Tage die Woche zu überwachen und auf Alarme zu reagieren. Es muss jedoch darauf geachtet werden, dass der Outsourcer über Änderungen an der zu überwachenden Umgebung, z. B. die Installation neuer Webanwendungen oder Änderungen an Serversystemen und -diensten usw., angemessen informiert wird, damit das IDS/IPS entsprechend neu konfiguriert werden kann.

IDS/IPS erfolgreich einsetzen

- Einschränkungen von IDS/IPS erkennen
- Fakt: IDS / IPS können umgangen werden
- Fakt: Beim IPS werden oft nur ein Bruchteil der verfügbaren Signaturen im Blocking-Modus aktiviert
- Die eigene Umgebung verstehen
- Was muss geschützt werden?
(welche Anwendungen? Welche Netzwerkprotokolle?)
- Was sind die Sicherheitsrisiken?
(Wahrscheinlich nicht uralte Angriffe usw.)
- Realistische und aussagekräftige Tests durchführen
- Eigene Signaturen definieren
- Ressourcen nicht unterschätzen
- Policies und Prozeduren definieren

Erfolgskriterien (1)

- Beim Einsatz von IDS/IPS ist es von entscheidender Bedeutung, die Grenzen der aktuellen Technologie zu erkennen. Es ist zum Beispiel kein Geheimnis, dass immer Methoden gefunden werden können, um zumindest einige der Angriffssignaturen zu umgehen (z. B. die Port-Scan-Erkennung).

Selbst wenn ein IPS potenziell Tausende von verschiedenen Angriffsarten erkennen kann, ist es in der Realität so, dass ein IPS höchstwahrscheinlich nur eine sehr begrenzte Anzahl davon aktiv (d. h. im Blockiermodus) hat, da es zu Fehlalarmen und damit zur Unterbrechung des legitimen Netzwerkverkehrs kommen kann.

In einigen Fällen können die Einschränkungen eines IDS/IPS mit alternativen Mechanismen reduziert werden, z. B. mit lokal geschriebenen Tools und Skripten, lokalen Erweiterungen bestehender Anwendungen (anwendungsbasiertes IDS, zur Ergänzung host- oder netzwerkbasierter Sensoren) usw.

Erfolgskriterien (2)

- Ein überraschender Fehler, der von einigen Unternehmen bei der Implementierung von IDS/IPS gemacht wird, ist das Versäumnis, die Natur der zu schützenden Umgebung vollständig zu verstehen (oder in einigen Fällen sogar zu berücksichtigen). Welche Arten von Anwendungen müssen geschützt werden? (Webserver? Datenbankserver?) Welche Netzwerkprotokolle sind in dem zu schützenden Netzwerksegment aktiv? Welche Ports sind durch die Firewall zugelassen? Betrachten wir als Beispiel ein IDS/IPS, das zwischen dem Web-Applikationsserver (z.B. Websphere) und dem Datenbankserver (z.B. Oracle) installiert wird. Was ist der Vorteil eines IDS/IPS, das nur für die Erkennung von HTTP-Angriffen konfiguriert ist? In diesem Fall sind die für Oracle SQLnet relevanten Angriffssignaturen viel wichtiger. Ausserdem: Auf welchem Port lauscht der Datenbankserver (nicht unbedingt TCP 1521) Überwacht das IDS/IPS den richtigen TCP-Port?
- Bei der Planung einer IDS/IPS-Implementierung ist es wichtig, die Art der Umgebung und die damit verbundenen Sicherheitsrisiken zu berücksichtigen. Ausserdem kann ein bestimmtes Gerät aufgrund der Unterstützung von Tausenden von verschiedenen Signaturen besser sein als das Produkt eines Mitbewerbers, aber sind diese Signaturen wirklich von Nutzen, wenn die meisten veraltet sind (z. B. phf, ping of death, verschiedene alte Signaturen im Zusammenhang mit IIS4 usw.) oder für Ihre Systeme nicht relevant sind?

Erfolgskriterien (3)

- Bei der Evaluierung oder Installation eines bestimmten IDS/IPS-Produkts ist es üblich, eine Reihe von Sicherheitstests durchzuführen. Es muss sichergestellt werden, dass diese Tests realistisch und für die zu schützende Umgebung relevant sind und dass die Ergebnisse richtig interpretiert werden. Ein einfacher automatischer Scan mit Hunderten von Tests zeigt beispielsweise nicht unbedingt an, dass die Sicherheitsstufe erhöht wurde, insbesondere wenn die entsprechenden Netzwerkprotokolle weder aktiv noch durch die Firewall zugelassen sind. Ein weiteres zu berücksichtigendes Problem ist, dass ein IDS/IPS mehrere Alarme für einen einzigen Angriffstyp generieren kann. Das heisst, wenn z. B. 100 Tests durchgeführt und 90 Alarme ausgelöst werden, bedeutet das nicht unbedingt, dass 10 Angriffe nicht erkannt wurden, die tatsächliche Anzahl könnte viel höher sein.
- Obwohl kommerzielle Produkte in der Regel Tausende von verschiedenen Angriffssignaturen enthalten, wird kein IDS oder IPS mit einem kompletten Satz vordefinierter Signaturen geliefert, die vollständig auf Ihre lokale Umgebung abgestimmt sind. Aus diesem Grund ist es äusserst wichtig, sich die Zeit zu nehmen, zusätzliche Angriffssignaturen zu entwickeln, die speziell auf die lokale Infrastruktur und Anwendungen zugeschnitten sind. Die meisten Produkte ermöglichen die Erstellung von benutzerdefinierten Angriffssignaturen - nutzen Sie diese!

Erfolgskriterien (4)

- Die meisten Unternehmen unterschätzen ernsthaft die Ressourcen, die für die Wartung und den Betrieb von IDS/IPS erforderlich sind, insbesondere für die Analyse, Auswertung und Untersuchung der vielen Alarmmeldungen, die unweigerlich generiert werden. Wenn man die Personalkosten mit einbezieht, sind die Gesamtkosten deutlich höher als der Anschaffungspreis.
- Beim Einsatz eines IDS oder IPS ist es wichtig, dass auch entsprechende Richtlinien und Verfahren entwickelt werden. Was werden Sie tun, wenn tatsächlich ein Sicherheitsvorfall eintritt?

Schlussfolgerungen (kompakt)

- IDS/IPS ist ein Konzept und kein Produkt
- Sonstige technischen IDS/IPS Möglichkeiten berücksichtigen
z.B. Firewalls, File Integrity Tools, Honeytokens usw.
- Applikationssicherheit nicht vergessen
Z.B. zielgerichtete Konfiguration und Auswertung von Applikationsspezifischen Logs
- Geschäftsrelevante Sicherheitsaspekte nicht vergessen
Z.B. Zugriff auf Gehaltsdaten, finanzieller Betrug usw.
- Das Thema IDS/IPS umfasst die ganze IT und ist nicht nur für die Netzwerkgruppe relevant
- IDS/IPS müsste als Teil eines SIEM Konzepts berücksichtigt werden

Schlussfolgerungen (ausführlich)

- In dieser Präsentation wurden sowohl die positiven als auch die negativen Aspekte von Intrusion Detection und Prevention Systemen vorgestellt. Trotz der Tatsache, dass einige der negativen Aspekte sicherlich sehr schwerwiegend sind, ist festzustellen, dass IDS/IPS eine wichtige Rolle in der Sicherheitsumgebung einer Organisation spielen und dass diese nicht als irrelevant oder unnötig abgetan werden sollten. Intrusion Detection/Prevention-Systeme können vorteilhaft eingesetzt werden, vorausgesetzt es werden einige wichtige Punkte beachtet:
- IDS/IPS sollten als Konzept und nicht einfach als Produkt betrachtet werden. Zu viele Unternehmen machen den Fehler, sich auf ein einziges Produkt zu verlassen, das das gesamte Spektrum der Intrusion Detection und Prevention abdeckt. Dies führt in der Regel schnell zu Enttäuschung und Desillusionierung.
- Zusätzlich zu den spezifischen IDS/IPS-Produkten muss die Vielzahl zusätzlicher technischer Möglichkeiten in Betracht gezogen werden, wie z. B. Firewalls (z. B. spezifische Firewall-Regeln, die so konfiguriert sind, dass sie Alarme auslösen), Tools zur Bewertung der Dateiintegrität, Honeytokens (z. B. Dummy-Benutzerkonten), Netzwerkzugangskontrollsysteme usw. Im Allgemeinen können bei der Intrusion Detection und Prevention erhebliche Fortschritte erzielt werden, wenn man die Vorstellungskraft nutzt und die vorhandene Infrastruktur besser ausnutzt.

Schlussfolgerungen (ausführlich)

- In der Praxis konzentriert sich IDS/IPS traditionell in erster Linie auf die Netzwerksicherheit, gefolgt von der Sicherheit des Betriebssystems. Vergessen Sie aber nicht, dass Intrusion Detection und Prevention auch für die Anwendungssicherheit relevant ist und dass durch eine sorgfältige und zielgerichtete Konfiguration und Auswertung von Anwendungslogdateien potenziell erhebliche Informationen gewonnen werden können.
- Bei der Entwicklung eines IDS/IPS-Konzepts sind nicht nur die technischen IT-Aspekte wie Netzwerk, Betriebssysteme, Datenbanken etc. zu berücksichtigen, sondern auch die betriebswirtschaftlichen Aspekte in Bezug auf Geschäftsdaten und Geschäftsprozesse. Zum Beispiel unbefugter Zugriff auf Personal-(Gehalts-) Daten, Finanzbetrug usw.
- In vielen Organisationen wird IDS/IPS als die Domäne der Netzwerkgruppe betrachtet. Zumindest ist IDS/IPS aber auch für Datenbanken, Betriebssysteme etc. relevant und damit für alle IT-Fachabteilungen anwendbar. Tatsächlich bezieht sich IDS/IPS auch auf Geschäftsanwendungen und erfordert daher ein Verständnis von Geschäftsdaten und Geschäftsprozessen. Als solches ist IDS/IPS für die gesamte IT-Abteilung relevant und muss daher auf einer entsprechenden Organisationsebene geführt und verwaltet werden.